Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

S.NO	NAME	COLLEGE	CONTACT
1.	Devi.s	Navarasam arts and science college for women	devi30112005@gmail.com
2.	Gopika.d	Navarasam arts and science college for women	dgopika214@gmail.com
3.	Monisha.v	Navarasam arts and science college for women	monishav25806@gami.com
4.	Vaishnavi.v	Navarasam arts and science college for women	v43810051@gmail.com

ABSTRACT

The rapid growth of digital technologies and online services has increased the need for strong network security systems. Traditional security models depend mainly on perimeter-based protection and Virtual Private Networks (VPNs). However, these methods often provide broad network access, which can create major security risks if a user's credentials are compromised. Attackers can easily move across internal networks and access sensitive data. Therefore, modern organizations require a more secure and flexible security model to protect their digital resources.

This project focuses on implementing **Zero Trust Network Access (ZTNA)** using Zscaler to ensure secure connectivity between users and applications. The Zero Trust model is based on the concept of **"Never Trust, Always Verify."** Instead of granting users full access to the network, the system verifies the user's identity and device security before allowing access to specific applications. Each access request is carefully evaluated based on identity, device posture, location, and security policies.

The proposed system also integrates **AI-based behaviour monitoring** to analyse user activities and detect unusual behaviour patterns. By continuously monitoring user actions, the system can quickly identify potential security threats such as unauthorized access attempts or suspicious activities. This helps prevent cyber-attacks, data breaches, and unauthorized system usage.

The implementation of ZTNA using Zscaler improves network security by hiding internal applications from the internet, reducing attack surfaces, and enforcing strict access control policies. The system also provides centralized monitoring and logging, which allows administrators to track user activities and detect security incidents in real time.

Overall, this project aims to develop a secure and scalable security architecture that ensures safe access to internal applications while protecting organizational data from modern cyber threats.

INTRODUCTION

In today's digital world, organizations rely heavily on online platforms, cloud services, and remote access technologies to perform daily operations. Employees, students, and administrators often access internal systems from different locations and devices. While this improves flexibility and productivity, it also introduces various cybersecurity risks such as unauthorized access, phishing attacks, malware infections, and data breaches.

Traditional network security models operate on the assumption that users inside the network can be trusted. These models typically use firewalls and VPNs to protect the network perimeter. However, once a user successfully connects to the network through a VPN, they may gain access to multiple internal resources, even if they only need access to a specific application. This approach increases the risk of lateral movement by attackers if a user account or device becomes compromised.

To overcome these challenges, modern cybersecurity strategies are shifting toward the Zero Trust security model. Zero Trust eliminates the concept of trusted internal networks and instead requires verification for every access request. Every user, device, and application must be authenticated and authorized before any connection is established.

This project introduces a Zero Trust Network Access system using Zscaler, a cloud-based security platform. The system ensures that users can only access specific applications they are authorized to use. Instead of connecting users to the entire network, the system establishes secure encrypted connections directly between the user and the required application.

Additionally, the system includes AI-powered behaviour monitoring to analyze user activities and detect anomalies. By continuously evaluating user behaviour and device security, the system ensures that any suspicious activity is detected and addressed immediately.

The adoption of Zero Trust architecture significantly improves organizational security, reduces attack surfaces, and enhances protection against modern cyber threats.

OBJECTIVES OF THE PROJECT

- The main objectives of this project are:
    - To understand the concept of Zero Trust security architecture.
    - To implement secure user-to-application connectivity using Zscaler.
    - To eliminate traditional VPN-based network access.
    - To ensure identity-based authentication and access control.
    - To detect and analyse vulnerabilities in web applications.
    - To provide recommendations for improving system security.
    - To implement continuous monitoring and logging of user activities.
    - To protect sensitive data from unauthorized access.
    - To reduce cyber threats such as phishing, malware, and credential theft.
    - To enhance the overall security posture of the organization

OVERVIEW OF PLATFORM

The platform used in this project includes several security tools and technologies to ensure effective implementation of Zero Trust architecture.

The primary platform used is **Zscaler**, which is a cloud-based cybersecurity solution that provides secure internet access and private application access.

The platform consists of the following components:

Zscaler Private Access (ZPA)

Provides secure access to internal applications without exposing the network.

Identity Provider

Verifies user identities using authentication methods such as multi-factor authentication.

App Connectors

Software components deployed inside the organization network to connect applications to the Zscaler cloud.

Security Monitoring

Logs and monitors user activities for threat detection.

Threat Intelligence

Identifies malicious domains, IP addresses, and suspicious activities.

This platform ensures that only authenticated and authorized users can access applications.

USE CASE SCENARIO

Scenario 1: Secure Faculty Access

A faculty member needs to access the university ERP system remotely. Using ZTNA, the system verifies the user identity and device security before allowing access.

Output:
• Identity verified
• Device posture checked
• Secure connection established

Scenario 2: External Research Access

External researchers require temporary access to a database. Zscaler grants limited access only to that specific application.

Output:
• Temporary access granted
• Network remains hidden
• Session monitored

Scenario 3: Student Examination Portal

Students access the online examination portal securely using authenticated connections.

Output:
• Secure login
• Controlled application access
• Protection from cyber attacks

STAGE-1

OVERVIEW

focuses on **web application vulnerability testing**.

The OWASP Top 10 security framework is used to identify common security risks. Vulnerability scanning tools are used to analyze web applications and detect security weaknesses. The analysis includes:

• Identifying vulnerabilities
• Understanding attack methods
• Evaluating security risks
• Implementing mitigation strategies

This stage helps organizations understand security weaknesses before attackers exploit them.

LIST OF VULNERABILITY TABLE

Practice Website:

S.No	Vulnerability Name	CWE Number
1	Improper Sanitization of File Paths	CWE-284
2	Invalid Certificate	CWE-395
3	Missing X-Frame Options	CWE-1021
4	X-Content Type Header Missing	CWE-918
5	Drupal API Vulnerability	CWE-20
6	Cross Site Scripting	CWE-79
7	Denial of Service	CWE-400
8	TLS Protocol Detection	CWE-327
9	Information Disclosure	CWE-497
10	Weak Cipher Suites	CWE-20

Main Website:

S.no	Vulnerability Name	CWE - No
1	SL Medium Strength Cipher Suites Supported (SWEET32)	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor
2	Cookie SERVERID created without secure flag	CWE-79: Improper Neutralisation of Input During Web Page Generation
3	X-Content-Type Options Header Missing	CWE-918: Server-Side Request Forgery (SSRF)
4	Denial of Service	CWE -400: Uncontrolled Resource Consumption
5	OS Identification	CWE-200: Exposure of Sensitive Information to an Unauthorised Actor

REPORT: -

Practice Website: http://www.itsecgames.com/

1) Vulnerability Name: Improper Sanitization of File Paths

CWE- 284: Improper Access Control

OWASP Category: A01:2021-Broken Access Control

Definition:
Improper sanitization of file paths occurs when a web application does not properly validate user input related to file locations. Attackers may exploit this vulnerability to access unauthorized files or sensitive information stored on the server. This can lead to exposure of confidential system data.

Steps to Reproduce: https://www.shodan.io/host/31.3.96.40

Recommendation:
Implement proper input validation and restrict file access permissions. Use secure coding practices and apply access control mechanisms to ensure users can only access authorized files.

2) Vulnerability Name: Invalid Certificate

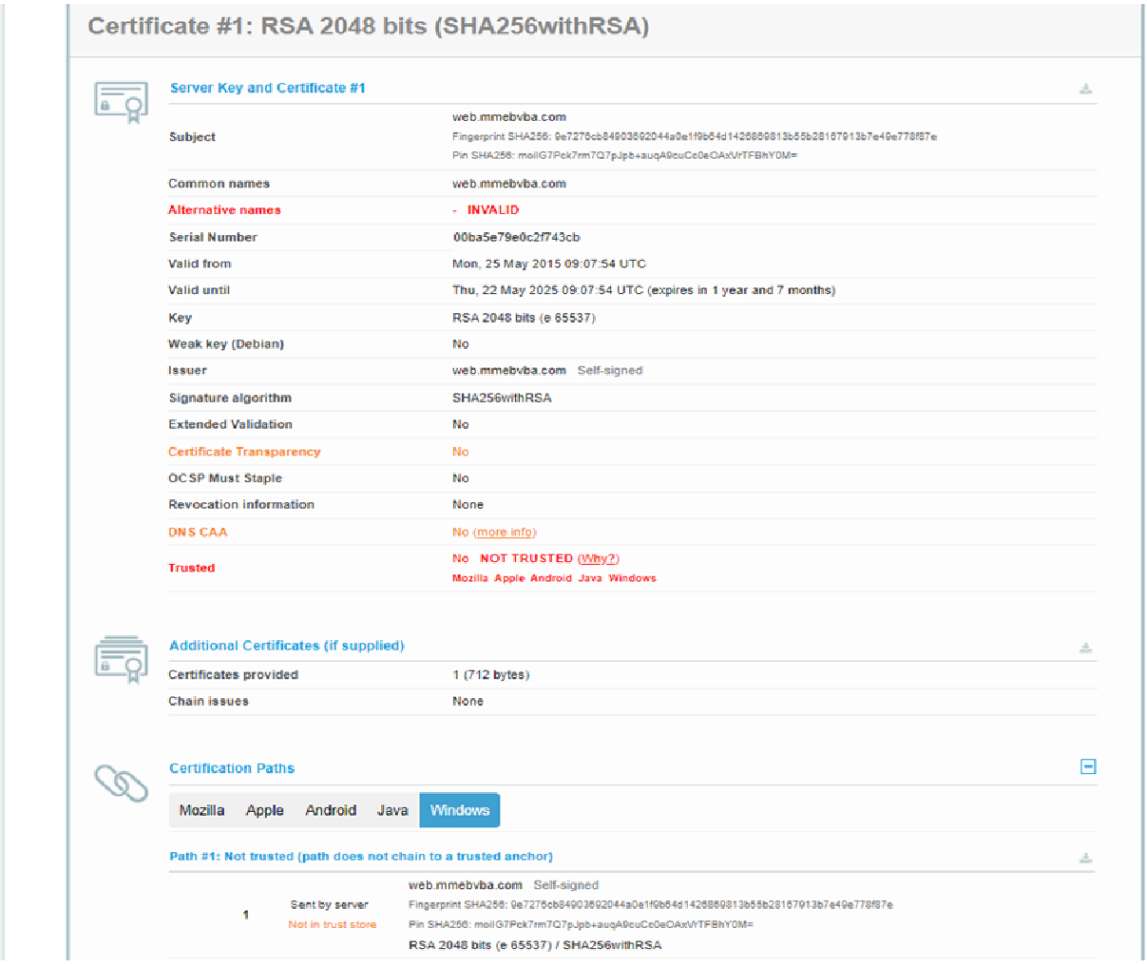
CWE-395: Improper Certificate Validation

OWASP Category: A07:2021 – Identification and Authentication Failures

Definition:
An invalid certificate indicates that the SSL/TLS certificate used by the website is not properly verified or trusted. This can weaken the secure communication between the client and the server and may allow attackers to intercept data.

Recommendation:
Use certificates issued by trusted Certificate Authorities (CA). Ensure proper certificate validation and regularly update or renew expired certificates.

Steps to Reproduce:
https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com



Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7275cb84903692044a0e1f9b64d1426869813b55b28157913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+auqA9cuCc0eOAxVrTFBhY0M=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expires in 1 year and 7 months)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	No
OCSP Must Staple	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)
Chain issues	None

Certification Paths

Mozilla Apple Android Java Windows

Path #1: Not trusted (path does not chain to a trusted anchor)

1	Sent by server Not in trust store	web.mmebvba.com Self-signed Fingerprint SHA256: 9e7275cb84903692044a0e1f9b64d1426869813b55b28157913b7e49e778f87e Pin SHA256: moilG7Pck7rm7Q7pJpb+auqA9cuCc0eOAxVrTFBhY0M= RSA 2048 bits (e 65537) / SHA256withRSA

3) Vulnerability Name: Missing X-Frame-Options Header

CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames

OWASP Category: A04:2021-Insecure Design

Definition:
The absence of the X-Frame-Options header allows the website to be loaded inside an iframe on another website. This may lead to clickjacking attacks where users are tricked into clicking malicious elements.

Vulnerability Path: http://www.itsecgames.com/

Recommendation:
Enable the X-Frame-Options header in the server configuration to prevent the website from being embedded in unauthorized frames.

4) Vulnerability Name: X-Content-Type Options Header Missing CWE - 918: Server-Side Request Forgery (SSRF)

OWASP Category: A10:2021 – Server-Side Request Forgery (SSRF)

Description: The web server receives a URL or similar request from an upstream component and retrieves the contents of this URL, but it does not sufficiently ensure that the request is being sent to the expected destination.

Vulnerability Path:
https://securityheaders.com/?q=http%3A%2F%2Fwww.itsecgames.com%2F&followRedirects= on

Recommendation:
Configure the server to include the **X-Content-Type-Options: nosniff** header to prevent browsers from interpreting files incorrectly.

5) Vulnerability Name: Drupal Ajax API shows JSONP not disabled by default

CWE-937,1035: OWASP Top Ten 2013,2017 Category A9 - Using Components with Known Vulnerabilities

OWASP Category: A06:2021-Vulnerable and Outdated Components

Description: Vulnerable and outdated components refer to using software libraries, modules, or dependencies within a web application that have known security issues or are not updated to the latest secure versions. This can include

plugins, frameworks, or APIs that are no longer maintained or have publicly documented vulnerabilities.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Recommendation:
Update Drupal components regularly and disable unnecessary modules. Ensure that only trusted APIs are enabled.

6) Vulnerability Name: Drupal Api Vulnerability CWE-20: Improper Input Validation

OWASP Category: A03:2021 – Injection

Description: The product receives input or data, but it does not validate or incorrectly validates that the input has the properties that are required to process the data safely and correctly.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Recommendation:
Apply security patches regularly and implement strong input validation. Secure coding techniques should be followed to prevent API misuse.

7) Vulnerability Name: Improper API Filtration

CWE-79: Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting')

OWASP Category: A07-2017: Cross-site Scripting (XSS)

Description: The product does not neutralize or incorrectly neutralizes user-controllable input before it is placed in output that is used as a web page that is served to other users.

Vulnerability Path: https://www.shodan.io/host/31.3.96.40

Recommendation:
Sanitize and validate all user inputs. Use output encoding and implement Content Security Policy (CSP) to reduce XSS risks.

8) Vulnerability Name: Denial of Service

CWE -400: Uncontrolled Resource Consumption

Definition:
A Denial-of-Service attack happens when attackers send excessive requests to a server, overwhelming its resources. As a result, legitimate users may not be able to access the service.

Recommendation:
Implement traffic monitoring, rate limiting, and Web Application Firewall (WAF) protection to reduce the impact of DoS attacks.

9) Vulnerability Name: TLS Version 1.0 Protocol Detection

CWE-327: Use of a Broken or Risky Cryptographic Algorithm **OWASP Category:** A02:2021-Cryptographic Failures

Description: The product uses a broken or risky cryptographic algorithm or protocol.

Recommendation:
Disable TLS 1.0 and enable stronger protocols such as TLS 1.2 or TLS 1.3 to ensure secure communication.

10) Vulnerability Name: web.config File Information Disclosure

CWE-497: Exposure of Sensitive System Information to an Unauthorized Control Sphere

OWASP Category: A3:2017-Sensitive Data Exposure

Definition:
If the web.config file is publicly accessible; it may reveal sensitive configuration details such as database credentials or server settings.

Recommendation:
Restrict access to configuration files and encrypt sensitive information. Proper server permissions should be configured to protect system files.

STAGE-2

OVERVIEW

The project focuses on identifying vulnerabilities in the target system using the Nessus vulnerability scanning tool. In this stage, the network and web application are scanned to detect security weaknesses and configuration issues. The scanning process helps in discovering outdated protocols, weak encryption methods, and server misconfigurations. Several vulnerabilities such as TLS protocol weaknesses, missing security headers, and information disclosure issues are identified during the scan. These vulnerabilities may expose the system to potential cyber-attacks if they are not properly addressed. The results of the scan provide detailed information about the severity and impact of each vulnerability. Based on the scan results, appropriate security recommendations are suggested to mitigate the identified risks. Overall, Stage-2 helps improve the security posture of the system by detecting and analysing vulnerabilities before they can be exploited by attackers.

Nessus is a widely used vulnerability assessment tool that scans networks and systems to identify security issues.

Features of Nessus include:

- Network scanning
- Vulnerability detection
- Risk assessment
- Security reporting

Nessus uses plugins to detect vulnerabilities in operating systems, applications, and network services.

Target website: - http://testfire.net/

Target Ip address: - 65.61.137.117

List of vulnerability: -

s.no	Vulnerability name	Severity	plugins
1	TLS Version 1.0 Protocol Detection	MEDIUM	104743
2	TLS Version 1.1 Protocol Deprecated	MEDIUM	157288
3	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875
4	ICMP Timestamp Request Remote Date Disclosure	INFO	10114
5	Additional DNS Hostnames	INFO	46180
6	Apache Tomcat Detection	INFO	39446
7	Common Platform Enumeration (CPE)	INFO	45590
8	Device Type	INFO	54615
9	HSTS Missing from HTTPS Server	INFO	84502
10	HTTP Server Type and Version	INFO	10107

REPORT: -

1) Vulnerability Name: - 104743 - TLS Version 1.0 Protocol Detection
Severity: - MEDIUM

Plugin: - 104743

Port: - 443

Description:
TLS 1.0 is an outdated encryption protocol used for secure communication between client and server. It contains several security weaknesses that attackers can exploit to intercept sensitive data.

Solution: - Enable support for TLS 1.2 and 1.3 and disable support for TLS 1.0.

2) Vulnerability Name: - 157288 - TLS Version 1.1 Protocol Deprecated
Severity: - MEDIUM

Plugin: - 157288

Port: - 443

Description:
TLS 1.1 is an older encryption protocol that is no longer recommended for secure communications. Systems using this protocol may be vulnerable to security attacks.

Solution: - Enable support for TLS 1.2 and/or 1.3 and disable support for TLS 1.1.

3) Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam) Severity: - LOW

Plugin: - 83875

Port: - 443

Description:
This vulnerability occurs when the server uses weak Diffie-Hellman keys for encryption. Attackers may exploit this weakness to break encrypted communication and access confidential information.

Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

4) Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure Severity: - INFO

Plugin: - 10114

Port: - 0

Description:
The system responds to ICMP timestamp requests which reveal the system's internal time information. Attackers may use this information for network reconnaissance and attack planning.

Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

5) Vulnerability Name: - 46180 - Additional DNS Hostnames Severity: - INFO

Plugin: - 46180

Port: - 0

Description:
The vulnerability scan detected additional DNS hostnames associated with the system. This may expose internal infrastructure details to attackers.

Solution: - If you want to test them, re-scan using the special vhost syntax, such as: www.example.com [192.0.32.10]

6) Vulnerability Name: - 39446 - Apache Tomcat Detection Severity: - INFO

Plugin: - 39446

Port: - 80

Description:

-Nessus was able to detect a remote Apache Tomcat web server.

Solution: - n/a

7) Vulnerability Name: - 45590 - Common Platform Enumeration (CPE) Severity: - INFO

Plugin: - 45590

Port: - 0

Description:

- By using information obtained from a Nessus scan, this plugin reports CPE (Common Platform Enumeration) matches for various hardware and software products found on a host.

Note that if an official CPE is not available for the product, this plugin computes the best possible CPE based on the information available from the scan.

Solution: - n/a

8) Vulnerability Name: - Device Type Severity: - INFO

Plugin: - 54615

Port: - 0

Description: - Based on the remote operating system, it is possible to determine what the remote system type is (eg: a printer, router, general-purpose computer, etc).

9) Vulnerability Name: - 84502 - HSTS Missing from HTTPS Server
Severity: - INFO

Plugin: - 84502

Port: - 443

Description: -The remote HTTPS server is not enforcing HTTP Strict Transport Security (HSTS). HSTS is an optional response header that can be configured on the server to instruct the browser to only communicate via HTTPS. The lack of HSTS allows downgrade attacks, SSL- stripping man-in-the-middle attacks and weakens cookie-hijacking protections.

Solution: - Configure the remote web server to use HSTS**.**

10) Vulnerability Name: - 10107 - HTTP Server Type and Version Severity: - INFO

Plugin: - 10107

Port: - 443

Description: - This plugin attempts to determine the type and the version of the remote web server.

Solution: - N/A

Stage-3

Implementation of ZTNA using Zscaler

Introduction

Stage-3 of the project focuses on implementing Zero Trust Network Access (ZTNA) using the Zscaler platform. In this stage, the previously identified vulnerabilities and security risks are addressed by applying a Zero Trust security model. The traditional network security approach assumes that users inside the network are trusted, but modern cyber threats require a stronger security model. ZTNA eliminates implicit trust and verifies every user, device, and connection before granting access to applications.

The Zscaler platform enables secure access to internal applications without exposing the internal network to the internet. By using identity-based authentication and secure cloud gateways, organizations can ensure that only authorized users can access specific applications. This approach significantly reduces the risk of cyber-attacks, unauthorized access, and data breaches.

Zscaler Platform Overview

Zscaler is a cloud-based security platform that provides secure internet access and Zero Trust Network Access for organizations. It acts as a security gateway between users and applications, ensuring that all traffic is inspected and verified before access is granted.

The Zscaler platform provides several security features such as secure web gateway, firewall protection, threat prevention, and access control. These features work together to protect users and applications from malicious threats. Instead of connecting users directly to the corporate network, Zscaler connects users only to the specific application they are authorized to use.

This architecture reduces the attack surface and prevents attackers from moving laterally within the network. Since the platform is cloud-based, it also provides scalability and easier management compared to traditional VPN solutions.

Zero Trust Security Model

The Zero Trust security model is based on the principle of **“Never Trust, Always Verify.”** This means that every access request must be authenticated and authorized before access is granted. Even if a user is inside the organization’s network, the system does not automatically trust the connection.

In the ZTNA model, user identity, device status, location, and security policies are evaluated before providing access to applications. This ensures that only legitimate users with verified devices can access sensitive resources.

Zero Trust architecture also provides micro-segmentation, which limits access only to specific applications instead of the entire network. This prevents attackers from moving across systems if one part of the network is compromised.

Implementation Process

The implementation of ZTNA using Zscaler involves several steps to ensure secure and controlled access to applications.

The first step is creating a Zscaler account and configuring the Zscaler cloud platform. The administrator sets up the required security policies and access rules based on organizational requirements.

The next step involves integrating the identity provider such as Active Directory or other authentication services. This ensures that user authentication is performed before access is granted.

After authentication integration, the administrator defines application access policies. These policies determine which users or groups are allowed to access specific applications. Access control is based on user identity rather than network location.

The system then establishes a secure connection between users and applications through the Zscaler cloud. Instead of connecting users directly to the internal network, the connection is brokered by Zscaler, ensuring that the internal infrastructure remains hidden from external users.

Security Mechanisms in ZTNA

ZTNA with Zscaler provides several security mechanisms to protect applications and data.

One important mechanism is **identity-based authentication**, where users must verify their identity before accessing applications. This prevents unauthorized users from gaining access to sensitive resources.

Another important feature is **application segmentation**. Users are only able to access the specific applications they are authorized for, rather than the entire network. This reduces the risk of lateral movement by attackers.

Zscaler also provides **continuous monitoring and threat detection**, which helps identify suspicious activities and potential security threats. Any abnormal activity is immediately flagged and blocked to prevent attacks.

Encryption and secure communication protocols are also used to ensure that data transmitted between users and applications remains confidential and protected.

Benefits of Using Zscaler ZTNA

Implementing ZTNA using Zscaler provides several advantages for organizations. It enhances overall security by eliminating implicit trust and verifying every access request. This significantly reduces the risk of unauthorized access and cyber-attacks.

Another benefit is improved visibility and control over user access. Administrators can monitor user activities and enforce security policies easily through the Zscaler management console.

Zscaler also improves performance and scalability since it operates through a cloud-based infrastructure. Organizations do not need to maintain complex hardware or traditional VPN systems.

Additionally, the ZTNA model improves remote access security, which is particularly important for organizations with remote employees or distributed work environments.

Conclusion

demonstrates the implementation of Zero Trust Network Access using the Zscaler platform to secure user-to-application connectivity. By applying the Zero Trust model, organizations can ensure that every user and device is verified before access is granted.

The Zscaler platform provides a secure and scalable solution that protects applications without exposing the internal network to external threats. Through

identity-based authentication, access control policies, and continuous monitoring, ZTNA significantly improves the overall security posture of the organization.

This stage highlights how modern security solutions like Zscaler can effectively protect systems from cyber threats while providing secure and efficient access to organizational resources.